TRUELINE IT

2026 PIPEDA Compliance Guide

Is your business actually PIPEDA compliant?

Trueline IT | Published 2026

Executive summary

78% of the businesses we assessed lack a documented privacy policy that meets PIPEDA standards. If your business collects customer data — names, emails, phone numbers, IP addresses, employee records, purchase history, or financial data — you are legally required to comply with the Personal Information Protection and Electronic Documents Act (PIPEDA) where that law applies.

This guide explains what PIPEDA requires, walks through the 10 core principles, identifies the most common compliance gaps we see, and lays out a practical, ten-step path to compliance.

What PIPEDA is, and who it applies to

PIPEDA is Canada's federal privacy law governing how for-profit organizations collect, use, and disclose personal information. Personal information includes any data that identifies an individual or could reasonably identify them. It does not apply to information held purely for personal, family, or household purposes, but any business data is squarely covered.

The 10 core PIPEDA principles

1. Accountability. Designate a privacy officer and document your privacy practices. You must be able to demonstrate compliance.

2. Identifying purposes. Be clear about why you collect data before you collect it. Vague or undisclosed purposes violate PIPEDA.

3. Consent. Obtain explicit, informed consent from individuals before collecting or using their data. Pre-ticked boxes don't count.

4. Limiting collection. Collect only the personal information you actually need for the stated purpose. Don't collect "just in case."

5. Limiting use. Use data only for the purposes disclosed at collection. Any new use requires fresh consent.

6. Accuracy. Keep personal information accurate, complete, and up-to-date. Stale data is a compliance violation.

7. Safeguarding. Apply technical, physical, and organizational measures to protect data: encryption, access controls, and breach protocols.

8. Openness. Make privacy practices transparent and accessible. Your policy must be easy to find and understand.

9. Individual access. Allow individuals to access their personal information and request corrections where inaccurate.

10. Challenging compliance. Provide a process to file privacy complaints and challenge your compliance. You need a mechanism to handle disputes.

Where businesses fall short

In our 2026 assessment of 20 businesses across legal, accounting, financial, and healthcare sectors, we found the same gaps recurring:

No documented privacy policy — 78%. Most businesses can't produce a policy that holds up to scrutiny.

Inadequate consent. Data is collected without clear, documented consent mechanisms.

Unencrypted data. Customer databases, shared passwords, and missing role-based access controls leave data exposed.

Indefinite retention. Data is held forever without a documented justification or deletion schedule.

No breach protocol. Most firms lack procedures for detecting, investigating, and reporting breaches, which is itself a legal requirement.

No staff training. Employees aren't trained on privacy obligations or how to handle sensitive data securely.

10 steps to PIPEDA compliance

1. Conduct a privacy audit. Map every type of personal data you collect, where it lives, who accesses it, and how long you keep it.

2. Document your privacy practices. Publish a clear, plain-language privacy policy, easy to find on your website.

3. Implement consent processes. Obtain explicit, informed consent for all data collection and honor opt-outs immediately.

4. Encrypt sensitive data in transit (HTTPS) and at rest, including customer databases and backups.

5. Limit access with role-based access controls and multi-factor authentication, and log who touches what data.

6. Create a data retention schedule. Define how long each data type is kept, then securely delete it on expiry.

7. Establish a breach response plan: detection, investigation, documentation, and reporting.

8. Train your team. Annual privacy training so staff can identify and handle sensitive data correctly.

9. Appoint a privacy officer, someone accountable for oversight, complaints, and audits.

10. Review annually. Audit compliance at least once a year and update as the business evolves.

What happens if you don't comply

The Privacy Commissioner of Canada takes violations seriously. Non-compliance can lead to formal complaints, investigations, binding compliance orders, reputational damage, and liability for breaches. The Commissioner holds the authority to issue findings of violation and enforcement orders, and enforcement is escalating. Privacy regulators and the Canadian Centre for Cyber Security publish guidance that courts and insurers increasingly weigh.

How Trueline IT helps

Compliance doesn't have to be overwhelming. We help you assess current practices, build documented PIPEDA-aligned policies, implement encryption and access controls, define retention schedules, create breach-response procedures, and train staff, then keep it current with annual audits.

Trueline AI governance retainers start at **$1,500/month per business**, covering your AI acceptable use policy, shadow AI audit, M365 configuration, and insurer-ready compliance documentation. No per-seat billing.

© 2026 Trueline IT — 1250 Brant Street, Suite 400, Burlington, ON L7P 1X8
hello@truelineit.com | (647) 360-5774 | truelineit.com